

Weekly IT Security Brief (Official-source-first) | 2026-05-31

06:06

Formatted for readability · Auto-generated

Weekly Summary

- Priority snapshot: 5 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2026-0257(2026-06-01), CVE-2026-48027(2026-06-10), CVE-2026-45321(2026-06-10). Prioritize internet-facing and privileged systems first.
- Threat trend #1: Malicious npm packages abuse dependency confusion to profile developer environments. A dependency confusion campaign leveraged 33 malicious npm packages to collect reconnaissance data from developer and build environments. This report details...
- Threat trend #2: Microsoft is named a Leader in the 2026 Gartner® Magic Quadrant™ for Endpoint Protection. Microsoft is named a Leader in the 2026 Gartner® Magic Quadrant™ for Endpoint Protection. The post Microsoft is named a Leader in the 2026 Gartner® Magi...
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.

Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2026-0257

CVE Title	CVE-2026-0257 paloaltonetworks/pan-os Auth Bypass
CVE Description	Authentication bypass vulnerabilities in the GlobalProtect portal and gateway of Palo Alto Networks PAN-OS® software allows the attacker to bypass security restrictions and establish an unauthorized VPN connection.
Root Cause	Authentication workflow has logical flaws allowing bypass.
Exploitation Prerequisite	Target service is network-reachable and accepts attacker-crafted unauthorized requests.
Exploit Path	Unauthorized request -> auth bypass -> sensitive data access / privileged operations.
Affected Products	paloaltonetworks/pan-os, paloaltonetworks/prisma_access
Risk Score	9.1 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-06-01
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-0257

CVE-2026-48027

CVE Title	CVE-2026-48027 nx/nx_console Unknown Type
CVE Description	Nx Console is the user interface for Nx & Lerna. On 19 May 2026, a malicious version of Nx Console, 18.95.0, was published at 12:30 PM UTC and removed soon after at 12:48 PM UTC, leaving it available for ~18 minutes in Visual Studio Marketplace. For OpenVSX, the problem was detected later, and the compromised version was available from 12:33 UTC to 13:09 UTC (~36 minutes). Version 18.100.0 of Nx Console is not c...
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	nx/nx_console
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-06-10
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-48027

CVE-2026-45321

CVE Title	CVE-2026-45321 tanstack/tanstack\arktype-adapter Unknown Type
CVE Description	On 2026-05-11, between approximately 19:20 and 19:26 UTC, 84 malicious versions across 42 @tanstack/* packages were published to the npm registry. The publishes were authenticated via the legitimate GitHub Actions OIDC trusted-publisher binding for TanStack/router, but the publish workflow itself was not modified. The attacker chained three known vulnerability classes — a pull_request_target "Pwn Request"...
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	tanstack/tanstack\arktype-adapter, tanstack/tanstack\eslint-plugin-router, tanstack/tanstack\eslint-plugin-start, tanstack/tanstack\history, tanstack/tanstack\nitro-v2-vite-plugin
Risk Score	9.6 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-06-10
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-45321

CVE-2026-8398

CVE Title	CVE-2026-8398 disc-soft/daemon_tools Unknown Type
CVE Description	A supply chain attack compromised the official installation packages of DAEMON Tools Lite (Windows versions 12.5.0.2421 through 12.5.0.2434), distributed from the legitimate website daemon-tools.cc between approximately April 8, 2026, and May 5, 2026. Attackers gained unauthorized access to the vendor's (AVB Disc Soft) build or distribution infrastructure and trojanized three binaries: DTHelper.exe, DiscSoftBus...
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	disc-soft/daemon_tools, microsoft/windows
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-05-30
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-8398

CVE-2026-48172

CVE Title	CVE-2026-48172 litespeedtech/litespeed_cpanel_plugin Privilege Escalation
CVE Description	LiteSpeed User-End cPanel Plugin before 2.4.5 allows privilege escalation (possibly to root), as exploited in the wild in May 2026. Detection is best done via a command line of <code>grep -rE "cpanel_jsonapi_func=redisAble" /var/cpanel/logs /usr/local/cpanel/logs/2>/dev/null</code> in Bash. If you get no output, you have not been hit with exploitation of the vulnerability. If there is output, we recommend you exami...
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	litespeedtech/litespeed_cpanel_plugin, litespeedtech/litespeed_whm_plugin
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-05-29
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-48172



Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-9342

CVE Title	CVE-2026-9342 待核實 SQL Injection
CVE Description	A security flaw has been discovered in SourceCodester Hospitals Patient Records Management System 1.0. Impacted is an unknown function of the file /admin/patients/view_history.php. The manipulation of the argument ID results in sql injection. The attack may be launched remotely. The exploit has been released to the public and may be used for attacks.
Affected Products	待核實
Risk Score	6.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-9342

CVE-2026-9343

CVE Title	CVE-2026-9343 待核實 Unknown Type
CVE Description	A weakness has been identified in Edimax EW-7438RPh up to 1.31. The affected element is the function formWpsStart of the file /goform/formWpsStart of the component webs. This manipulation of the argument pinCode causes os command injection. Remote exploitation of the attack is possible. The exploit has been made available to the public and could be used for attacks. The vendor was contacted early about this disclosu...
Affected Products	待核實
Risk Score	6.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-9343

CVE-2026-9344

CVE Title CVE-2026-9344 | 待核實 | Buffer Overflow

CVE Description A security vulnerability has been detected in Edimax EW-7438RPn up to 1.31. The impacted element is an unknown function of the file /goform/formWpsStart of the component webs. Such manipulation of the argument pinCode/wlan-url leads to stack-based buffer overflow. The attack can be executed remotely. The exploit has been disclosed publicly and may be used. The vendor was contacted early about this disclosure but did...

Affected Products 待核實

Risk Score 8.8 (HIGH)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-9344>

CVE-2026-9345

CVE Title CVE-2026-9345 | 待核實 | Buffer Overflow

CVE Description A vulnerability was detected in Edimax EW-7438RPn up to 1.31. This affects the function formWizSurvey of the file /goform/formWizSurvey of the component webs. Performing a manipulation of the argument ssid/manualssid/ip/mask/gateway results in buffer overflow. The attack is possible to be carried out remotely. The exploit is now public and may be used. The vendor was contacted early about this disclosure but did not...

Affected Products 待核實

Risk Score 8.8 (HIGH)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-9345>

CVE-2026-9346

CVE Title CVE-2026-9346 | 待核實 | Buffer Overflow

CVE Description A flaw has been found in Edimax EW-7438RPn up to 1.31. This impacts the function formWirelessTbl of the file /goform/formWirelessTbl of the component webs. Executing a manipulation of the argument submit-url can lead to buffer overflow. The attack may be performed from remote. The exploit has been published and may be used. The vendor was contacted early about this disclosure but did not respond in any way.

Affected Products 待核實

Risk Score 8.8 (HIGH)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-9346>

CVE-2026-9347

CVE Title CVE-2026-9347 | 待核實 | Unknown Type

CVE Description A vulnerability has been found in Edimax EW-7438RPn up to 1.31. Affected is the function formWizSurvey of the file /goform/formWizSurvey of the component webs. The manipulation of the argument ip/mask/gateway leads to os command injection. It is possible to initiate the attack remotely. The exploit has been disclosed to the public and may be used. The vendor was contacted early about this disclosure but did not resp...

Affected Products 待核實

Risk Score 6.3 (MEDIUM)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-9347>



Report B: Threat Intelligence News (last 7 days)

Headline: Malicious npm packages abuse dependency confusion to profile developer environments

Source	Microsoft Security Blog
Published	Sat, 30 May 2026 00:06:20 +0000
Key Takeaway	A dependency confusion campaign leveraged 33 malicious npm packages to collect reconnaissance data from developer and build environments. This report details the attack chain, observed tradecraft, and detection opportunities to help organizations identify and disrupt related activity. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	Reconnaissance
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/05/29/33-malicious-npm-packages-abuse-dependency-confusion-profile-developer-environments/

Headline: Microsoft is named a Leader in the 2026 Gartner® Magic Quadrant™ for Endpoint Protection

Source	Microsoft Security Blog
Published	Fri, 29 May 2026 16:00:00 +0000
Key Takeaway	Microsoft is named a Leader in the 2026 Gartner® Magic Quadrant™ for Endpoint Protection. The post Microsoft is named a Leader in the 2026 Gartner® Magic Quadrant™ for Endpoint Protection appeared first on Microsoft Security Blog . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/05/29/microsoft-is-named-a-leader-in-the-2026-gartner-magic-quadrant-for-endpoint-protection/

Headline: CISA Announces Revised Town Hall Schedule to Engage with Stakeholders on Cyber Incident Reporting for Critical Infrastructure

Source	CISA News
Published	Tue, 26 May 26 12:00:00 +0000
Key Takeaway	CISA Announces Revised Town Hall Schedule to Engage with Stakeholders on Cyber Incident Reporting for Critical Infrastructure
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	critical infrastructure/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-announces-revised-town-hall-schedule-engage-stakeholders-cyber-incident-reporting-critical

Headline: CISA Enhances Known Exploited Vulnerabilities Catalog to Include New Nomination Form

Source	CISA News
Published	Thu, 21 May 26 12:00:00 +0000
Key Takeaway	CISA Enhances Known Exploited Vulnerabilities Catalog to Include New Nomination Form
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-enhances-known-exploited-vulnerabilities-catalog-include-new-nomination-form

Headline: Exploitation of KnowledgeDeliver via ViewState Deserialization Vulnerability

Source	Mandiant Blog
Published	Mon, 25 May 2026 14:00:00 +0000
Key Takeaway	Mandiant identified a critical vulnerability that allowed unauthenticated Remote Code Execution (RCE). This vulnerability stems from the use of identical pre-shared ASP.NET machine keys across multiple customer deployments. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/japan
Technique	Malware Deployment
MITRE ATT&CK	Unverified
Related CVEs	CVE-2026-5426
Link	https://cloud.google.com/blog/topics/threat-intelligence/knowledgedeliver-viewstate-deserialization-vulnerability/

Headline: 2 PhaaS 2 Furious: The Evolution of Chinese-Language Phishing Services

Source Mandiant Blog

Published Mon, 25 May 2026 14:00:00 +0000

Key Takeaway While Russian-speaking threat actors have historically dominated the phishing-as-a-service (PhaaS) landscape, a rival ecosystem is rapidly growing within the Chinese-language underground. By utilizing live administration panels, attackers can interact with victims in real-time to capture one-time pa Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target defense/europe

Technique Social Engineering

MITRE ATT&CK Unverified

Related CVEs None

Link <https://cloud.google.com/blog/topics/threat-intelligence/chinese-language-phishing-services/>

Headline: Less panic patching, more precision

Source	Cisco Talos Blog
Published	Thu, 28 May 2026 18:00:27 GMT
Key Takeaway	Less panic patching, more precision Blog Intelligence Center Intelligence Center BACK Intelligence Search Email & Spam Trends Vulnerability Research Vulnerability Research BACK Vulnerability Reports Microsoft Advisories Incident Response Incident Response BACK Reactive Services Proactive Services Em Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/less-panic-patching-more-precision/

Headline: DICOM, Pydicom, GDCM, and Orthanc: A technical tour of what really happens in the heap

Source	Cisco Talos Blog
Published	Thu, 28 May 2026 10:00:52 GMT
Key Takeaway	This white paper presents a concrete case study demonstrating the creation of a heap overflow vulnerability through the exploitation of the DICOM file format. DICOM, Pydicom, GDCM, and Orthanc: A technical tour of what really happens in the heap Blog Intelligence Center Intelligence Center BACK Inte Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/dicom-pydicom-gdcm-and-orthanc-a-technical-tour-of-what-really-happens-in-the-heap/

Headline: PAN-OS GlobalProtect Authentication Bypass (CVE-2026-0257) Under Active Exploitation

Source	The Hacker News
Published	Sat, 30 May 2026 12:11:26 +0530
Key Takeaway	Palo Alto Networks has warned that a recently disclosed medium-severity security flaw impacting PAN-OS and Prisma Access has come under active exploitation in the wild. The vulnerability, tracked as CVE-2026-0257 (CVSS score: 7.8), refers to a case of authentication bypass that could be exploited by Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/global
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	CVE-2026-0257
Link	https://thehackernews.com/2026/05/pan-os-globalprotect-authentication.html

Headline: ChatGPhish Vulnerability Turns ChatGPT Web Summaries Into a Phishing Surface

Source	The Hacker News
Published	Fri, 29 May 2026 23:37:12 +0530
Key Takeaway	Cybersecurity researchers have disclosed details of a vulnerability in OpenAI ChatGPT that leverages the artificial intelligence (AI) assistant's implicit trust in Markdown links and images to trigger prompt injections and open the door to phishing attacks. "The chatgpt.com response renderer trusts Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/la...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Phishing
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/05/chatgphish-vulnerability-turns-chatgpt.html

Headline: Russian Spies Are Aggressively Seeking Western Technology as Sanctions Bite, Officials Say

Source	SecurityWeek
Published	Sat, 30 May 2026 16:00:49 +0000
Key Takeaway	Russian Spies Are Aggressively Seeking Western Technology as Sanctions Bite, Officials Say - SecurityWeek SECURITYWEEK NETWORK: Cybersecurity News Webcasts Virtual Events ICS: ICS Cybersecurity Conference Malware & Threats Cyberwarfare Cybercrime Data Breaches Fraud & Identity Theft Nation-State Ran Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lat...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/russian-spies-are-aggressively-seeking-western-technology-as-sanctions-bite-officials-say/

Headline: Exploit Code Published for Critical Flowise RCE Vulnerability

Source	SecurityWeek
Published	Sat, 30 May 2026 15:55:59 +0000
Key Takeaway	The one-click vulnerability allows attackers to execute arbitrary code on self-hosted Flowise servers by tricking users into importing a malicious chatflow. The post Exploit Code Published for Critical Flowise RCE Vulnerability appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/exploit-code-published-for-critical-flowise-rce-vulnerability/



Sources (official/authoritative first)

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

<https://nvd.nist.gov/>

<https://www.cve.org/>

<https://attack.mitre.org/>

[**https://www.microsoft.com/en-us/security/blog/**](https://www.microsoft.com/en-us/security/blog/)

[**https://www.cisa.gov/news-events/cybersecurity-advisories**](https://www.cisa.gov/news-events/cybersecurity-advisories)

[**https://www.mandiant.com/resources**](https://www.mandiant.com/resources)

[**https://blog.talosintelligence.com/**](https://blog.talosintelligence.com/)